



ΚΥΠΡΙΑΚΗ ΔΗΜΟΚΡΑΤΙΑ



ΓΡΑΦΕΙΟ ΕΠΙΤΡΟΠΟΥ ΠΡΟΣΤΑΣΙΑΣ
ΔΕΔΟΜΕΝΩΝ ΠΡΟΣΩΠΙΚΟΥ
ΧΑΡΑΚΤΗΡΑ

Ε Π Ι Τ Ρ Ο Π Ο Σ

Αρ. Φακ.: 12.10.001.011.006.005.032

ΑΠΟΦΑΣΗ

Περιστατικό παραβίασης δεδομένων προσωπικού χαρακτήρα σχετικά με ανάρτηση αριθμών δελτίων ταυτότητας εκπαιδευτικών λειτουργών

Αναφέρομαι στη Γνωστοποίηση περιστατικού παραβίασης δεδομένων προσωπικού χαρακτήρα που καταχωρίστηκε στο Γραφείο μου στις 21 Απριλίου 2023, σχετικά με την ανάρτηση αριθμών δελτίων ταυτότητας εκπαιδευτικών λειτουργών στην ιστοσελίδα της Επιτροπής Εκπαιδευτικής Υπηρεσίας και σε όλη τη σχετική με το ανωτέρω θέμα αλληλογραφία, η οποία αποτελεί μέρος του φακέλου της υπόθεσης. Στο πλαίσιο της εξέτασης της Γνωστοποίησης με βάση τις εξουσίες που μου απονέμουν τα άρθρα 33(5) και 55(1) του Κανονισμού του Ευρωπαϊκού Κοινοβουλίου και του Συμβουλίου για την προστασία των φυσικών προσώπων έναντι της επεξεργασίας των δεδομένων προσωπικού χαρακτήρα και για την ελεύθερη κυκλοφορία των δεδομένων αυτών, (ΕΕ) 2016/679 (εφεξής ο «Κανονισμός»), διαπίστωσα παράβαση του Κανονισμού από την Επιτροπή Εκπαιδευτικής Υπηρεσίας (εφεξής η «Επιτροπή») και, ως εκ τούτου, εκδίδω την παρούσα Απόφαση.

A. Περιστατικό

2. Στο έντυπο Γνωστοποίησης του περιστατικού, ως επίσης στην επιστολή της Υπηρεσίας, ημερομηνίας 7 Σεπτεμβρίου 2023, προς απάντηση επιστολής του Γραφείου μου, ημερομηνίας 9 Αυγούστου 2023, αναφέρονται τα ακόλουθα:

- 2.1. στις 20 Απριλίου 2023, γύρω στις 12:00 μ., η Επιτροπή ανήρτησε στην ιστοσελίδα της, την καθιερωμένη ανακοίνωση με τις μονάδες μετάθεσης των εκπαιδευτικών λειτουργών,
- 2.2. η εν λόγω ανακοίνωση ήταν σε μορφή excel,
- 2.3. πέραν των ονοματεπωνύμων, εκ παραδρομής περιλήφθηκε στήλη με τους αριθμούς δελτίων ταυτότητας των εκπαιδευτικών,
- 2.4. «το λάθος» έγινε αντιληπτό στις 21 Απριλίου 2023 και ώρα 10:00 π.μ., μετά από τηλεφώνημα που έλαβε η Υπηρεσία από εκπαιδευτικό λειτουργό,
- 2.5. η Επιτροπή προέβη αμέσως στην αφαίρεση της στήλης η οποία περιελάμβανε τους αριθμούς δελτίων ταυτότητας των εκπαιδευτικών.

3. Το περιστατικό παραβίασης ξεκίνησε στις 20 Απριλίου 2023 και ώρα 12:00 μ. Στις 21 Απριλίου 2023 και ώρα 10:00 π.μ. η Επιτροπή έλαβε γνώση και το περιστατικό έληξε την ίδια στιγμή. Η ενημέρωση για το περιστατικό έγινε μετά από τηλεφώνημα εκπαιδευτικού.
4. Λόγω του περιστατικού, παραβιάστηκαν τα ακόλουθα δεδομένα: ονοματεπώνυμο, αριθμός δελτίου ταυτότητας και αριθμός φακέλου. Δεν παραβιάστηκαν δεδομένα ειδικών κατηγοριών.
5. Το περιστατικό αφορά σε δεδομένα 11.300 εργαζομένων (κατά προσέγγιση), τα οποία ήταν αποθηκευμένα σε πέντε αρχεία.
- 6.1. Το περιστατικό αφορά σε παραβίαση της εμπιστευτικότητας δεδομένων προσωπικού χαρακτήρα. Συγκεκριμένα, μπορεί να υπάρξει προσπέλαση στα δεδομένα σε βαθμό μεγαλύτερο από ό,τι ήταν αναγκαίο ή για τον οποίο τα πρόσωπα είχαν δώσει συγκατάθεση. Ωστόσο τα δεδομένα που αφορά το περιστατικό δεν μπορούν να συσχετιστούν με άλλα προσωπικά δεδομένα των ιδίων προσώπων και δεν μπορούν να χρησιμοποιηθούν για άλλους σκοπούς ενδεχομένως αθέμιτους.
- 6.2. Το περιστατικό δεν αφορά σε παραβίαση της διαθεσιμότητας δεδομένων προσωπικού χαρακτήρα.
- 6.3. Το περιστατικό δεν αφορά σε παραβίαση της ακεραιότητας των δεδομένων που παραβιάστηκαν.
7. Το περιστατικό οφείλεται σε ανθρώπινο λάθος. Ως φύση του περιστατικού έχει προσδιοριστεί η δημοσίευση / κοινοποίηση δεδομένων εκ παραδρομής.
8. Ως φύση των πιθανών συνεπειών έχει καταγραφεί η δημοσιοποίηση του αριθμού δελτίου ταυτότητας των εκπαιδευτικών. Η Επιτροπή έχει αξιολογήσει τη σοβαρότητα των πιθανών συνεπειών ως μικρή.
9. Μέχρι την υποβολή του εντύπου Γνωστοποίησης, ως αναφέρεται σε αυτό, η Επιτροπή δεν είχε αποφασίσει ακόμη σχετικά με το αν έπρεπε να ενημερωθούν τα επηρεαζόμενα υποκείμενα των δεδομένων.
10. Στο έντυπο Γνωστοποίησης δεν αναγράφονταν μέτρα που λήφθηκαν πριν το περιστατικό.
11. Όσον αφορά στην αντιμετώπιση του περιστατικού, η Επιτροπή προέβη σε άμεση αφαίρεση των αρχείων από την ιστοσελίδα της. Ως αναφέρεται στο έντυπο Γνωστοποίησης, η Επιτροπή προτίθετο να επανεξετάσει τις διαδικασίες που αφορούν στη δημοσίευση των ανακοινώσεων ή δεδομένων των εκπαιδευτικών στην ιστοσελίδα της, με σκοπό την ελαχιστοποίηση, κατά το δυνατό, της έκθεσης δεδομένων τους για σκοπούς πλήρους συμμόρφωσης με τον Κανονισμό, λαμβάνοντας πάντα υπόψη και τις πρόνοιες της νομοθεσίας που αφορούν στη λειτουργία της Επιτροπής.
12. Η διαδικασία που ακολουθείτο πριν το περιστατικό ήταν η δημιουργία αρχείου excel στο οποίο περιλαμβάνονταν διάφορες κατηγορίες δεδομένων των εκπαιδευτικών λειτουργών και, ακολούθως, επιλέγονταν ποιες στήλες θα διατηρούνταν. Επίσης, υπεύθυνος για τη δημιουργία του αρχείου και της ανακοίνωσης, καθώς και για τη

δημοσίευση στην ιστοσελίδα της Επιτροπής ήταν ένας μόνο λειτουργός, χωρίς να γίνεται έλεγχος από άλλον λειτουργό πριν από την ανάρτηση.

13. Η Επιτροπή δεν είναι σε θέση να προσδιορίσει τεχνικά πόσες φορές ή/και αν μεταφορτώθηκαν (κατέβηκαν) τα εν λόγω αρχεία. Γνωρίζει, όμως, ότι κατά την χρονική περίοδο που ήταν αναρτημένη η ανακοίνωση επισκέφτηκαν την ιστοσελίδα της Επιτροπής είκοσι άτομα. Εντούτοις, αυτό δεν σημαίνει ότι κατ' ανάγκη και τα είκοσι αυτά άτομα είχαν πρόσβαση στην εν λόγω ανακοίνωση. Δηλαδή, η επισκεψιμότητα της ιστοσελίδας ήταν μικρή όταν η ανακοίνωση ήταν αναρτημένη.

14. Η Επιτροπή αποφάσισε να μην ενημερώσει τα επηρεαζόμενα υποκείμενα των δεδομένων για το περιστατικό της παραβίασης επειδή έκρινε ότι η σοβαρότητα των συνεπειών της παραβίασης ήταν μικρή, λόγω του ότι η διάρκεια που η εν λόγω ανακοίνωση ήταν αναρτημένη στην ιστοσελίδα της Επιτροπής ήταν περιορισμένη και λόγω του ότι ο αριθμός επισκεψιμότητας της ιστοσελίδας κατά την εν λόγω χρονική περίοδο ήταν, επίσης, μικρός. Πέραν τούτου, η Επιτροπή δεν έλαβε κανένα άλλο σχετικό παράπονο.

15. Εκ των υστέρων, και με αφορμή το περιστατικό, η Επιτροπή διαπίστωσε ότι δεν είχαν ληφθεί οποιαδήποτε μέτρα πριν το περιστατικό που θα μπορούσαν να αποτρέψουν το ενδεχόμενο ανθρώπινου «λάθους» για αποφυγή του περιστατικού και/ή περιορίσουν την παραβίαση. Επομένως, ως διορθωτικό μέτρο, η Επιτροπή αποφάσισε ότι η δημιουργία του αρχείου excel θα γίνεται εξ υπαρχής με τη δημιουργία στηλών που θα περιέχουν μόνο τις απαιτούμενες προς δημοσίευση κατηγορίες δεδομένων. Επίσης, θα διενεργείται έλεγχος πριν από τη δημοσίευση της ανακοίνωσης στην ιστοσελίδα από τον υπεύθυνο διοικητικό λειτουργό, ο οποίος θα είναι άλλος από τον λειτουργό που έχει την ευθύνη ετοιμασίας του αρχείου.

16. Η σοβαρότητα των πιθανών συνεπειών προσδιορίστηκε ως μικρή, αφού η χρονική διάρκεια που η εν λόγω ανακοίνωση ήταν αναρτημένη στην ιστοσελίδα της Επιτροπής ήταν περιορισμένη και ο αριθμός επισκεψιμότητας της ιστοσελίδας κατά την εν λόγω χρονική περίοδο ήταν επίσης μικρός.

17. Η Επιτροπή δεν έχει λάβει παράπονο και/ή ενημέρωση από επηρεαζόμενα υποκείμενα των δεδομένων, πέραν του εκπαιδευτικού ο οποίος ενημέρωσε την Επιτροπή στις 21 Απριλίου 2023 και ώρα 10:00 π.μ.

18. Στο σημείο αυτό, σημειώνω ότι μόλις έγινε αντιληπτό από την Επιτροπή ότι αναρτήθηκαν οι αριθμοί δελτίων ταυτότητας των εκπαιδευτικών στην ιστοσελίδα της Επιτροπής, και πριν την υποβολή του εντύπου Γνωστοποίησης, ο Πρόεδρος της Επιτροπής επικοινωνήσε τηλεφωνικά με το Γραφείο μου, αναφέροντας σε εμένα, αλλά και σε λειτουργό του Γραφείου μου το περιστατικό, ότι δόθηκαν άμεσα οδηγίες για αφαίρεση των εν λόγω αρχείων και ότι τα αρχεία αυτά είχαν ήδη αφαιρεθεί.

B. Νομικό Πλαίσιο

19. Σύμφωνα με το άρθρο 4 του Κανονισμού, τα δεδομένα προσωπικού χαρακτήρα ερμηνεύονται ως «κάθε πληροφορία που αφορά ταυτοποιημένο ή ταυτοποιήσιμο φυσικό πρόσωπο (*«υποκείμενο των δεδομένων»*): το ταυτοποιήσιμο φυσικό πρόσωπο είναι εκείνο του οποίου η ταυτότητα μπορεί να εξακριβωθεί, άμεσα ή έμμεσα, ιδίως μέσω αναφοράς σε αναγνωριστικό στοιχείο ταυτότητας, όπως όνομα, σε αριθμό ταυτότητας, σε δεδομένα

θέσης, σε επιγραμματικό αναγνωριστικό ταυτότητας ή σε έναν ή περισσότερους παράγοντες που προσιδιάζουν στη σωματική, φυσιολογική, γενετική, ψυχολογική, οικονομική, πολιτιστική ή κοινωνική ταυτότητα του εν λόγω φυσικού προσώπου».

Δυνάμει του ιδίου άρθρου, παραβίαση δεδομένων προσωπικού χαρακτήρα αποτελεί η «παραβίαση της ασφάλειας που οδηγεί σε τυχαία ή παράνομη καταστροφή, απώλεια, μεταβολή, άνευ άδειας κοινολόγηση ή πρόσβαση δεδομένων προσωπικού χαρακτήρα που διαβιβάστηκαν, αποθηκεύτηκαν ή υποβλήθηκαν κατ' άλλο τρόπο σε επεξεργασία».

Επίσης, στο ίδιο άρθρο ορίζεται ο υπεύθυνος επεξεργασίας ως «το φυσικό ή νομικό πρόσωπο, η δημόσια αρχή, η υπηρεσία ή άλλος φορέας που, μόνα ή από κοινού με άλλα, καθορίζουν τους σκοπούς και τον τρόπο της επεξεργασίας δεδομένων προσωπικού χαρακτήρα· όταν οι σκοποί και ο τρόπος της επεξεργασίας αυτής καθορίζονται από το δίκαιο της Ένωσης ή το δίκαιο κράτους μέλους, ο υπεύθυνος επεξεργασίας ή τα ειδικά κριτήρια για τον διορισμό του μπορούν να προβλέπονται από το δίκαιο της Ένωσης ή το δίκαιο κράτους μέλους».

20. Δυνάμει του άρθρου 24 του Κανονισμού, προνοούνται τα ακόλουθα:

«1. Λαμβάνοντας υπόψη τη φύση, το πεδίο εφαρμογής, το πλαίσιο και τους σκοπούς της επεξεργασίας, καθώς και τους κινδύνους διαφορετικής πιθανότητας επέλευσης και σοβαρότητας για τα δικαιώματα και τις ελευθερίες των φυσικών προσώπων, ο υπεύθυνος επεξεργασίας εφαρμόζει κατάλληλα τεχνικά και οργανωτικά μέτρα προκειμένου να διασφαλίζει και να μπορεί να αποδεικνύει ότι η επεξεργασία διενεργείται σύμφωνα με τον παρόντα κανονισμό. Τα εν λόγω μέτρα επανεξετάζονται και επικαιροποιούνται όταν κρίνεται απαραίτητο.

2. Όταν δικαιολογείται σε σχέση με τις δραστηριότητες επεξεργασίας, τα μέτρα που αναφέρονται στην παράγραφο 1 περιλαμβάνουν την εφαρμογή κατάλληλων πολιτικών για την προστασία των δεδομένων από τον υπεύθυνο επεξεργασίας.»

21. Επιπρόσθετα, για την ασφάλεια της επεξεργασίας, το άρθρο 32 του Κανονισμού προβλέπει, μεταξύ άλλων, ότι:

«1. Λαμβάνοντας υπόψη τις τελευταίες εξελίξεις, το κόστος εφαρμογής και τη φύση, το πεδίο εφαρμογής, το πλαίσιο και τους σκοπούς της επεξεργασίας, καθώς και τους κινδύνους διαφορετικής πιθανότητας επέλευσης και σοβαρότητας για τα δικαιώματα και τις ελευθερίες των φυσικών προσώπων, ο υπεύθυνος επεξεργασίας και ο εκτελών την επεξεργασία εφαρμόζουν κατάλληλα τεχνικά και οργανωτικά μέτρα προκειμένου να διασφαλίζεται το κατάλληλο επίπεδο ασφάλειας έναντι των κινδύνων, περιλαμβανομένων, μεταξύ άλλων, κατά περίπτωση:

- α) της ψευδωνυμοποίησης και της κρυπτογράφησης δεδομένων προσωπικού χαρακτήρα,
- β) της δυνατότητας διασφάλισης του απορρήτου, της ακεραιότητας, της διαθεσιμότητας και της αξιοπιστίας των συστημάτων και των υπηρεσιών επεξεργασίας σε συνεχή βάση,
- γ) της δυνατότητας αποκατάστασης της διαθεσιμότητας και της πρόσβασης σε δεδομένα προσωπικού χαρακτήρα σε εύθετο χρόνο σε περίπτωση φυσικού ή τεχνικού συμβάντος,

δ) διαδικασίας για την τακτική δοκιμή, εκτίμηση και αξιολόγηση της αποτελεσματικότητας των τεχνικών και των οργανωτικών μέτρων για τη διασφάλιση της ασφάλειας της επεξεργασίας.

2. Κατά την εκτίμηση του ενδεδειγμένου επιπέδου ασφάλειας λαμβάνονται ιδίως υπόψη οι κίνδυνοι που απορρέουν από την επεξεργασία, ιδίως από τυχαία ή παράνομη καταστροφή, απώλεια, αλλοίωση, άνευ αδείας κοινολόγηση ή προσπέλαση δεδομένων προσωπικού χαρακτήρα που διαβιβάστηκαν, αποθηκεύτηκαν ή υποβλήθηκαν κατ' άλλο τρόπο σε επεξεργασία.»

22. Δυνάμει του άρθρου 58(2) του Κανονισμού, η Επίτροπος Προστασίας Δεδομένων Προσωπικού Χαρακτήρα διαθέτει τις ακόλουθες διορθωτικές εξουσίες:

«α) να απευθύνει προειδοποιήσεις στον υπεύθυνο επεξεργασίας ή στον εκτελούντα την επεξεργασία ότι σκοπούμενες πράξεις επεξεργασίας είναι πιθανόν να παραβαίνουν διατάξεις του παρόντος κανονισμού,

β) να απευθύνει επιπλήξεις στον υπεύθυνο επεξεργασίας ή στον εκτελούντα την επεξεργασία όταν πράξεις επεξεργασίας έχουν παραβεί διατάξεις του παρόντος κανονισμού,

γ) να δίνει εντολή στον υπεύθυνο επεξεργασίας ή στον εκτελούντα την επεξεργασία να συμμορφώνεται προς τα αιτήματα του υποκειμένου των δεδομένων για την άσκηση των δικαιωμάτων του σύμφωνα με τον παρόντα κανονισμό,

δ) να δίνει εντολή στον υπεύθυνο επεξεργασίας ή στον εκτελούντα την επεξεργασία να καθιστούν τις πράξεις επεξεργασίας σύμφωνες με τις διατάξεις του παρόντος κανονισμού, εάν χρειάζεται, με συγκεκριμένο τρόπο και εντός ορισμένης προθεσμίας,

ε) να δίνει εντολή στον υπεύθυνο επεξεργασίας να ανακοινώνει την παραβίαση δεδομένων προσωπικού χαρακτήρα στο υποκείμενο των δεδομένων,

στ) να επιβάλλει προσωρινό ή οριστικό περιορισμό, περιλαμβανομένης της απαγόρευσης της επεξεργασίας,

ζ) να δίνει εντολή διόρθωσης ή διαγραφής δεδομένων προσωπικού χαρακτήρα ή περιορισμού της επεξεργασίας δυνάμει των άρθρων 16, 17 και 18 και εντολή κοινοποίησης των ενεργειών αυτών σε αποδέκτες στους οποίους τα δεδομένα προσωπικού χαρακτήρα γνωστοποιήθηκαν δυνάμει του άρθρου 17 παράγραφος 2 και του άρθρου 19,

η) να αποσύρει την πιστοποίηση ή να διατάξει τον οργανισμό πιστοποίησης να αποσύρει ένα πιστοποιητικό εκδοθέν σύμφωνα με τα άρθρα 42 και 43 ή να διατάξει τον οργανισμό πιστοποίησης να μην εκδώσει πιστοποίηση, εφόσον οι απαιτήσεις πιστοποίησης δεν πληρούνται ή δεν πληρούνται πλέον,

θ) να επιβάλλει διοικητικό πρόστιμο δυνάμει του άρθρου 83, επιπλέον ή αντί των μέτρων που αναφέρονται στην παρούσα παράγραφο, ανάλογα με τις περιστάσεις κάθε μεμονωμένης περίπτωσης,

ι) να δίνει εντολή για αναστολή της κυκλοφορίας δεδομένων σε αποδέκτη σε τρίτη χώρα ή σε διεθνή οργανισμό.»

23. Το άρθρο 83 του Κανονισμού, σχετικά με τους γενικούς όρους επιβολής διοικητικών προστίμων, προβλέπει ότι:

«1. Κάθε εποπτική αρχή μεριμνά ώστε η επιβολή διοικητικών προστίμων σύμφωνα με το παρόν άρθρο έναντι παραβάσεων του παρόντος κανονισμού που

αναφέρονται στις παραγράφους 4, 5 και 6 να είναι για κάθε μεμονωμένη περίπτωση αποτελεσματική, αναλογική και αποτρεπτική.

2. Τα διοικητικά πρόστιμα, ανάλογα με τις περιστάσεις κάθε μεμονωμένης περίπτωσης, επιβάλλονται επιπρόσθετα ή αντί των μέτρων που αναφέρονται στο άρθρο 58 παράγραφος 2 στοιχεία α) έως η) και στο άρθρο 58 παράγραφος 2 στοιχείο ι). Κατά τη λήψη απόφασης σχετικά με την επιβολή διοικητικού προστίμου, καθώς και σχετικά με το ύψος του διοικητικού προστίμου για κάθε μεμονωμένη περίπτωση, λαμβάνονται δεόντως υπόψη τα ακόλουθα:

- α) η φύση, η βαρύτητα και η διάρκεια της παράβασης, λαμβάνοντας υπόψη τη φύση, την έκταση ή το σκοπό της σχετικής επεξεργασίας, καθώς και τον αριθμό των υποκειμένων των δεδομένων που έθιξε η παράβαση και το βαθμό ζημίας που υπέστησαν,
- β) ο δόλος ή η αμέλεια που προκάλεσε την παράβαση,
- γ) οποιεσδήποτε ενέργειες στις οποίες προέβη ο υπεύθυνος επεξεργασίας ή ο εκτελών την επεξεργασία για να μετριάσει τη ζημία που υπέστησαν τα υποκείμενα των δεδομένων,
- δ) ο βαθμός ευθύνης του υπευθύνου επεξεργασίας ή του εκτελούντος την επεξεργασία, λαμβάνοντας υπόψη τα τεχνικά και οργανωτικά μέτρα που εφαρμόζουν δυνάμει των άρθρων 25 και 32,
- ε) τυχόν σχετικές προηγούμενες παραβάσεις του υπευθύνου επεξεργασίας ή του εκτελούντος την επεξεργασία,
- στ) ο βαθμός συνεργασίας με την αρχή ελέγχου για την επανόρθωση της παράβασης και τον περιορισμό των πιθανών δυσμενών επιπτώσεών της,
- ζ) οι κατηγορίες δεδομένων προσωπικού χαρακτήρα που επηρεάζει η παράβαση,
- η) ο τρόπος με τον οποίο η εποπτική αρχή πληροφορήθηκε την παράβαση, ειδικότερα εάν και κατά πόσο ο υπεύθυνος επεξεργασίας ή ο εκτελών την επεξεργασία κοινοποίησε την παράβαση,
- θ) σε περίπτωση που διατάχθηκε προηγουμένως η λήψη των μέτρων που αναφέρονται στο άρθρο 58 παράγραφος 2 κατά του εμπλεκόμενου υπευθύνου επεξεργασίας ή του εκτελούντος την επεξεργασία σχετικά με το ίδιο αντικείμενο, η συμμόρφωση με τα εν λόγω μέτρα,
- ι) η τήρηση εγκεκριμένων κωδίκων δεοντολογίας σύμφωνα με το άρθρο 40 ή εγκεκριμένων μηχανισμών πιστοποίησης σύμφωνα με το άρθρο 42 και
- ια) κάθε άλλο επιβαρυντικό ή ελαφρυντικό στοιχείο που προκύπτει από τις περιστάσεις της συγκεκριμένης περίπτωσης, όπως τα οικονομικά οφέλη που αποκομίστηκαν ή ζημιών που αποφεύχθηκαν, άμεσα ή έμμεσα, από την παράβαση.

3. Σε περίπτωση που ο υπεύθυνος επεξεργασίας ή ο εκτελών την επεξεργασία, για τις ίδιες ή για συνδεδεμένες πράξεις επεξεργασίας, παραβιάζει αρκετές διατάξεις του παρόντος κανονισμού, το συνολικό ύψος του διοικητικού προστίμου δεν υπερβαίνει το ποσό που ορίζεται για τη βαρύτερη παράβαση.

4. Παραβάσεις των ακόλουθων διατάξεων επισύρουν, σύμφωνα με την παράγραφο 2, διοικητικά πρόστιμα έως 10 000 000 EUR ή, σε περίπτωση επιχειρήσεων, έως το 2 % του συνολικού παγκόσμιου ετήσιου κύκλου εργασιών του προηγούμενου οικονομικού έτους, ανάλογα με το ποιο είναι υψηλότερο:

- α) οι υποχρεώσεις του υπευθύνου επεξεργασίας και του εκτελούντος την επεξεργασία σύμφωνα με τα άρθρα 8, 11, 25 έως 39 και 42 και 43,
- β) οι υποχρεώσεις του φορέα πιστοποίησης σύμφωνα με τα άρθρα 42 και 43,

γ) οι υποχρεώσεις του φορέα παρακολούθησης σύμφωνα με το άρθρο 41 παράγραφος 4.

5. Παραβάσεις των ακόλουθων διατάξεων επισύρουν, σύμφωνα με την παράγραφο 2, διοικητικά πρόστιμα έως 20 000 000 EUR ή, σε περίπτωση επιχειρήσεων, έως το 4 % του συνολικού παγκόσμιου ετήσιου κύκλου εργασιών του προηγούμενου οικονομικού έτους, ανάλογα με το ποιο είναι υψηλότερο:

α) οι βασικές αρχές για την επεξεργασία, περιλαμβανομένων των όρων που ισχύουν για την έγκριση, σύμφωνα με τα άρθρα 5, 6, 7 και 9,

β) τα δικαιώματα των υποκειμένων των δεδομένων σύμφωνα με τα άρθρα 12 έως 22,

γ) η διαβίβαση δεδομένων προσωπικού χαρακτήρα σε αποδέκτη σε τρίτη χώρα ή σε διεθνή οργανισμό σύμφωνα με τα άρθρα 44 έως 49,

δ) οποιεσδήποτε υποχρεώσεις σύμφωνα με το δίκαιο του κράτους μέλους οι οποίες θεσπίζονται δυνάμει του κεφαλαίου IX,

ε) μη συμμόρφωση προς εντολή ή προς προσωρινό ή οριστικό περιορισμό της επεξεργασίας ή προς αναστολή της κυκλοφορίας δεδομένων που επιβάλλει η εποπτική αρχή δυνάμει του άρθρου 58 παράγραφος 2 ή μη παροχή πρόσβασης κατά παράβαση του άρθρου 58 παράγραφος 1.»

24. Σχετικά με την επιβολή διοικητικού προστίμου, το άρθρο 32 του περί της Προστασίας των Φυσικών Προσώπων Έναντι της Επεξεργασίας των Δεδομένων Προσωπικού Χαρακτήρα και της Ελεύθερης Κυκλοφορίας των Δεδομένων αυτών Νόμου του 2018, Νόμος 125(I)/2018, προνοεί ότι:

«(1) Τηρουμένων των διατάξεων του άρθρου 83 του Κανονισμού, ο Επίτροπος επιβάλλει διοικητικό πρόστιμο.

(...)

(3) Διοικητικό πρόστιμο που επιβάλλεται σε δημόσια αρχή ή δημόσιο φορέα και αφορά σε δραστηριότητες μη κερδοσκοπικής φύσεως, δεν δύναται να υπερβαίνει τις διακόσιες χιλιάδες ευρώ (€200.000).»

Γ. ΣΚΕΠΤΙΚΟ

25. Για τις συγκεκριμένες πράξεις επεξεργασίας, δηλαδή την ετοιμασία των αρχείων excel και την ανάρτησή τους στην ιστοσελίδα της Επιτροπής, η Επιτροπή αποτελεί τον υπεύθυνο επεξεργασίας, αφού η ίδια έχει καθορίσει τους σκοπούς και τα μέσα της επεξεργασίας.

26. Επομένως, έχοντας τον ρόλο του υπεύθυνου επεξεργασίας, η Επιτροπή οφείλει όπως εκπληρώνει όλες τις υποχρεώσεις οι οποίες προκύπτουν από τον Κανονισμό.

27. Είναι σαφές ότι σκοπός των εν λόγω πράξεων επεξεργασίας ήταν η ενημέρωση των εκπαιδευτικών λειτουργών, σχετικά με τις μονάδες μετάθεσής τους. Στα αρχεία excel είχαν περιληφθεί το ονοματεπώνυμο, ο αριθμός δελτίου ταυτότητας και ο αριθμός φακέλου εκάστου εκπαιδευτικού. Τίθεται, επομένως, το ερώτημα κατά πόσο ο επιδιωκόμενος σκοπός, ήτοι η ενημέρωση των εκπαιδευτικών λειτουργών, θα μπορούσε να επιτευχθεί με την επεξεργασία λιγότερων δεδομένων.

28. Στο πλαίσιο αυτό, διαπιστώνεται ότι ο επιδιωκόμενος σκοπός θα μπορούσε να επιτευχθεί χωρίς την επεξεργασία, δηλαδή ανάρτηση, του αριθμού δελτίου ταυτότητας των εκπαιδευτικών. Επομένως, τα υπό επεξεργασία δεδομένα δεν περιορίστηκαν στο αναγκαίο για τον σκοπό για τον οποίο υποβλήθηκαν σε επεξεργασία, κατά παράβαση της αρχής της ελαχιστοποίησης, ήτοι του άρθρου 5(1)(γ) του Κανονισμού.

29. Το περιστατικό είχε ως συνέπεια να παραβιαστούν δεδομένα μεγάλου πλήθους υποκειμένων των δεδομένων. Ωστόσο, το γεγονός ότι τα υποκείμενα αυτά ήταν διαμοιρασμένα σε πέντε αρχεία, τα οποία αφορούσαν σε διαφορετική βαθμίδα εκπαίδευσης, σε συνδυασμό με τη μικρή επισκεψιμότητα στη σελίδα όταν ήταν αναρτημένη η ανακοίνωση, ενδεχομένως περιόρισε σε κάποιο βαθμό την παραβίαση των προσωπικών δεδομένων η οποία επισυνέβη.

30. Η Επιτροπή ανέφερε προς το Γραφείο μου ότι το περιστατικό οφείλεται σε ανθρώπινο λάθος και ότι έγινε εκ παραδρομής δημοσίευση / κοινοποίηση των δεδομένων.

31. Σύμφωνα με τη διαδικασία που ακολουθείτο, μόνο ένας λειτουργός είχε την ευθύνη για τη δημιουργία και την ανάρτηση της ανακοίνωσης, ο οποίος από το αρχικό αρχείο excel που περιείχε διάφορες κατηγορίες δεδομένων, διατηρούσε μόνο τις στήλες που έπρεπε να διατηρηθούν.

32. Βάσει της διαδικασίας που ανέφερε η Επιτροπή προς το Γραφείο μου, διαπιστώνω ότι το περιστατικό οφείλεται πρωτίστως στην έλλειψη οργανωτικών μέτρων, συγκεκριμένα στην απουσία διαδικασίας η οποία θα απέτρεπε να επισυμβεί το εν λόγω περιστατικό και, ακολούθως, οφείλεται σε ανθρώπινο λάθος.

33. Άλλωστε, το γεγονός ότι μετά το περιστατικό, η Επιτροπή καθόρισε διαδικασία, σύμφωνα με την οποία η δημιουργία του αρχείου excel θα γίνεται εξ αρχής με τη δημιουργία μόνο όσων στηλών απαιτούνται και, πριν την ανάρτησή της, θα διενεργείται έλεγχος από άλλο διοικητικό λειτουργό, δεικνύει ότι υπήρχαν μέτρα τα οποία η Επιτροπή θα μπορούσε να λάβει, τα οποία, όμως, δεν είχε λάβει.

34. Επομένως, δεν ήταν σε εφαρμογή κατάλληλα τεχνικά και οργανωτικά μέτρα προκειμένου να διασφαλιστεί το κατάλληλο επίπεδο ασφάλειας έναντι των κινδύνων, κατά παράβαση του άρθρου 32(1) του Κανονισμού.

35. Πέραν τούτου, δεν ήταν σε εφαρμογή κατάλληλες πολιτικές για την προστασία των δεδομένων, κατά παράβαση του άρθρου 24(1) του Κανονισμού.

36. Η Επιτροπή ανέφερε ότι η σοβαρότητα των πιθανών συνεπειών είναι μικρή, αφού τόσο ο χρόνος ανάρτησης της ιστοσελίδας, όσο και ο αριθμός επισκεψιμότητάς της ήταν μικρός. Λαμβάνοντας υπόψιν ότι ο αριθμός δελτίου ταυτότητας αποτελεί μοναδικό αναγνωριστικό των υποκειμένων των δεδομένων, το οποίο σε κάθε περίπτωση δεν ήταν απαραίτητο να τύχει επεξεργασίας, κρίνω ότι δεν ισχύει ότι η σοβαρότητα των πιθανών συνεπειών ήταν μικρή, αλλά ότι η πιθανότητα των πιθανών συνεπειών δεν είναι μεγάλη.

37. Επίσης, δεν ισχύει η θέση της Επιτροπής ότι τα δεδομένα που αφορούν στο περιστατικό δεν μπορούν να συσχετιστούν με άλλα προσωπικά δεδομένα των ιδίων προσώπων και ότι δεν μπορούν να χρησιμοποιηθούν για άλλους σκοπούς ενδεχομένως

αθέμιτους, αφού τα εν λόγω αρχεία περιελάμβαναν και τα ονοματεπώνυμα των εκπαιδευτικών λειτουργών.

38. Το γεγονός ότι η Επιτροπή ενήργησε τάχιστα, μετά την ενημέρωση που έλαβε από εκπαιδευτικό λειτουργό, δεικνύει ότι η Επιτροπή αντιλήφθηκε πλήρως την παραβίαση στην οποία προέβη. Επίσης, το γεγονός ότι υπήρχε άμεση εμπλοκή της Επιτροπής σε ανώτατο επίπεδο, αφού ο ίδιος ο Πρόεδρος της Επιτροπής επικοινωνήσε τηλεφωνικά με το Γραφείο μου, αναφέροντας το περιστατικό, επιβεβαιώνει τη σημασία που δόθηκε από την Επιτροπή, τόσο για την αποκατάσταση της παραβίασης, αλλά και για την τήρηση των υποχρεώσεων της Επιτροπής.

39. Αναγνωρίζω ως μετριαστικό παράγοντα το γεγονός ότι τόσο η Επιτροπή, πέραν από την αρχική ενημέρωση που έλαβε από εκπαιδευτικό λειτουργό, όσο και το Γραφείο μου, δεν έλαβαν παράπονο από άλλο εκπαιδευτικό λειτουργό.

40. Εντούτοις, αναγνωρίζω ως επιβαρυντικό παράγοντα, το γεγονός ότι στο έντυπο Γνωστοποίησης δεν αναγράφονταν μέτρα που λήφθηκαν πριν το περιστατικό.

Δ. Κατάληξη

41. Λαμβανομένων υπόψιν όλων των ανωτέρω στοιχείων, ως αυτά έχουν τεθεί, και με βάση τις εξουσίες που μου παρέχονται δυνάμει των άρθρων 33(5) και 55(1) του Κανονισμού, διαπιστώνω ότι υπάρχει παραβίαση από την Επιτροπή Εκπαιδευτικής Υπηρεσίας:

(α) του άρθρου 5(1)(γ) του Κανονισμού, αφού τα υπό επεξεργασία δεδομένα δεν περιορίστηκαν στο αναγκαίο για τον σκοπό για τον οποίο υποβλήθηκαν σε επεξεργασία, («ελαχιστοποίηση των δεδομένων»),

(β) του άρθρου 24(1) του Κανονισμού, αφού δεν εφαρμόστηκαν κατάλληλα τεχνικά και οργανωτικά μέτρα προκειμένου να διασφαλίζεται και να μπορεί να αποδεικνύεται ότι η επεξεργασία διενεργήθηκε σύμφωνα με τον Κανονισμό, και

(γ) του άρθρου 32(1) του Κανονισμού, αφού δεν εφαρμόζονταν κατάλληλα τεχνικά και οργανωτικά μέτρα προκειμένου να διασφαλίζεται το κατάλληλο επίπεδο ασφάλειας έναντι των κινδύνων.

42. Βάσει των προνοιών του άρθρου 83 του Κανονισμού, σχετικά με τους όρους επιβολής διοικητικών προστίμων, στο μέτρο που αυτές εφαρμόζονται στη συγκεκριμένη περίπτωση, κατά την επιμέτρηση του διοικητικού προστίμου, έλαβα υπόψιν τους ακόλουθους μετριαστικούς (α) - (θ) και επιβαρυντικούς (ι) - (ια) παράγοντες:

(α) τη μη ύπαρξη δόλου εκ μέρους του Επιτροπής,

(β) τις άμεσες ενέργειες που έλαβε η Επιτροπή μετά το περιστατικό,

(γ) τη συνεργασία της Επιτροπής με το Γραφείο μου, παρέχοντας τις ζητηθείσες πληροφορίες εντός των χρονοδιαγραμμάτων που έθεσα,

(δ) την εμπλοκή της Επιτροπής για αντιμετώπιση του περιστατικού σε ανώτατο επίπεδο,

(ε) τα μέτρα που έλαβε η Επιτροπή για αποφυγή επανάληψης του περιστατικού,

- (στ) το γεγονός ότι τα υποκείμενα των δεδομένων των οποίων παραβιάστηκαν δεδομένα ήταν διαμοιρασμένα σε πέντε αρχεία,
- (ζ) τη μικρή επισκεψιμότητα στην ιστοσελίδα της Επιτροπής και το μικρό διάστημα το οποίο ήταν αναρτημένα τα εν λόγω αρχεία,
- (η) την κατηγορία των δεδομένων που παραβιάστηκαν, η οποία δεν αφορά σε ειδικές κατηγορίες δεδομένων,
- (θ) το γεγονός ότι το Γραφείο μου δεν έλαβε σχετικό παράπονο, και ότι η Επιτροπή πέραν της αρχικής ενημέρωσης δεν έλαβε άλλο παράπονο από υποκείμενο των δεδομένων,
- (ι) το γεγονός ότι παραβιάστηκαν δεδομένων 11.300 εργαζομένων περίπου,
- (ια) την τήρηση διαδικασίας η οποία δεν ήταν ικανή να αποτρέψει το περιστατικό,

43. Αφού έλαβα υπόψιν και συνεκτίμησα:

- (α) το ισχύον νομοθετικό έρρισμα σχετικά με τις προβλεπόμενες διοικητικές κυρώσεις στις διατάξεις του άρθρου 58(2) και του άρθρου 83 του Κανονισμού,
- (β) όλες τις περιστάσεις και τους παράγοντες που η Επιτροπή έθεσε ενώπιόν μου με βάση όλη την υφιστάμενη αλληλογραφία,
- (γ) τους πιο πάνω μετριαστικούς και επιβαρυντικούς παράγοντες,

κρίνω ότι, υπό τις περιστάσεις δεν δικαιολογείται η επιβολή διοικητικού προστίμου.

44. Παρά ταύτα, έχοντας υπόψιν τα πιο πάνω γεγονότα, τη νομική πτυχή πάνω στην οποία βασίζεται η παρούσα Απόφαση και την ανάλυση όπως αυτή έχει επεξηγηθεί πιο πάνω, ασκώντας τις εξουσίες που μου παρέχει το άρθρο 58(2)(β), (δ) του Κανονισμού,

Αποφάσιμα

κατά την κρίση μου και τηρουμένων των ανωτέρω διατάξεων,

να απευθύνω στην Επιτροπή Εκπαιδευτικής Υπηρεσίας

Επίπληξη για την παραβίαση των άρθρων 5(1)(γ), 24(1) και 32(1) του Κανονισμού (ΕΕ) 2016/679

και

Εντολή όπως εντός δύο μηνών από τη λήψη της παρούσας Απόφασης:

- α) εκπαιδεύσει όλο το προσωπικό της Επιτροπής στη νομοθεσία της προστασίας προσωπικών δεδομένων,
- β) εκπαιδεύσει περαιτέρω τους εργαζομένους οι οποίοι ασχολούνται με τη δημιουργία αρχείων που περιέχουν προσωπικά δεδομένα εκπαιδευτικών λειτουργιών, τα οποία αναρτώνται στην ιστοσελίδα της Επιτροπής, σύμφωνα με γραπτή διαδικασία την οποία η Επιτροπή θα πρέπει να υποβάλει στο Γραφείο μου,

γ) ενημερώσει το Γραφείο μου για υλοποίηση των ανωτέρω, υποβάλλοντας σχετικά αποδεικτικά.

Ειρήνη Λοϊζίδου Νικολαΐδου
Επίτροπος Προστασίας
Δεδομένων Προσωπικού Χαρακτήρα

3 Ιουλίου 2024